
Incident Response Plan

Document Name: `Incident_Response_Plan.md`

Prepared For: Cybersecurity Basics I & VM Security Project

Prepared By: [Your Name]

Date: June 2025

1. Purpose

This plan outlines the procedures for detecting, responding to, and recovering from security incidents on a Linux-based network environment. It addresses cyber threats such as brute-force attacks, ransomware, phishing, and unauthorized access attempts, using real-world tools in a virtualized lab environment.

2. Scope

Applies to all Linux VMs used in the security project, especially the Ubuntu/Debian target VM configured with services such as SSH and web applications. The plan is designed to work in conjunction with implemented security controls like `ufw`, `fail2ban`, and file monitoring systems.

3. Incident Type Addressed

Attack Type: Brute-force attack on SSH using Hydra (can be classified under Credential Attacks and Denial of Service attempts if automated)

Tool Simulated: Kali Linux (`hydra`)

4. Detection

Method 1: Log Monitoring

- Review `/var/log/auth.log` or use a Python script (`monitor.py`) to detect multiple failed SSH login attempts.

Sample log entry:

log

CopyEdit

```
Jun 16 10:22:01 target sshd[1234]: Failed password for invalid user  
admin from 192.168.56.101 port 22 ssh2
```

-

Method 2: Intrusion Detection Tools

- Enable `fail2ban` with SSH filters to automatically detect brute-force attempts based on log behavior.
 - Monitor ban actions in `/var/log/fail2ban.log`
-

5. Containment Strategy

Short-term:

`fail2ban` immediately blocks the attacker's IP after N failed attempts.

bash

CopyEdit

```
sudo fail2ban-client status sshd
```

-

Use `ufw` to manually deny all incoming traffic from malicious IPs:

bash

CopyEdit

```
sudo ufw deny from 192.168.56.101 to any
```

-

Long-term:

- Change default SSH port in `/etc/ssh/sshd_config` (e.g., from 22 to 2200).

Enforce key-based authentication and disable root login:

conf

CopyEdit

```
PermitRootLogin no
```

```
PasswordAuthentication no
```

-

6. Eradication Steps

Terminate any suspicious active sessions using:

bash

CopyEdit

w

who

ps aux | grep ssh

pkill -KILL -u compromised_user

-
- Run antivirus scan (e.g., ClamAV) if a payload is suspected.
- Review and clean cron jobs, startup scripts, and temp directories.

7. Recovery Steps

- Change all potentially exposed passwords and SSH keys.
- Restore services with fresh configs from backups if tampered.
- Apply additional controls:
 - Enable 2FA for remote logins
 - Schedule regular audits of SSH logs
- Resume normal operation after confirming no persistence mechanisms remain.

8. Post-Incident Review

- Document timeline of attack, response actions, and impact.
- Log all IPs, tools used, and files affected.
- Conduct a retrospective with these questions:
 - What worked well?
 - What delayed detection or response?
 - What new control should be added?

9. Legal and Ethical Considerations

- Comply with data protection laws (e.g., GDPR or HIPAA) when collecting evidence.
- Maintain logs for legal chain of custody.
- Ensure responsible disclosure policies for vulnerabilities are followed.

✅ 10. Summary of Key Actions

Phase	Tools/Commands Used
Detection	<code>fail2ban</code> , log analysis, Python script
Containment	<code>ufw</code> , <code>fail2ban ban</code>
Eradication	<code>pkill</code> , user audit, antivirus scan
Recovery	Restore, rotate keys, reconfigure SSH

Comprehensive Security Policy

Document Name: `Security_Policy.md`

Prepared For: Cybersecurity Basics I Course / Linux VM Project

Prepared By: [Your Name]

Date: June 2025

1. Purpose and Scope

This security policy provides a framework for protecting Linux-based systems used in a virtualized cybersecurity testing environment. It defines technical and procedural controls necessary to secure virtual machines, detect and respond to incidents, and maintain the confidentiality, integrity, and availability of system data and services.

2. System Overview

The architecture includes:

- One or more **Linux target VMs** (Ubuntu/Debian) with services like SSH and possibly Apache.
- One **Kali Linux VM** used to simulate real-world attacks (e.g., Nmap, Hydra, Nikto).
- Network configured via Host-Only or NAT for isolation.

3. Key Security Rules and Guidelines

Rule 1: Secure Remote Access Configuration

- Disable root login over SSH (`PermitRootLogin no`)
- Enforce public key authentication (`PasswordAuthentication no`)
- Change default SSH port (e.g., from 22 to 2200)

Why? Prevents brute-force and unauthorized root access.

Rule 2: Firewall and Intrusion Prevention

Enable UFW (Uncomplicated Firewall) and define strict ingress rules:

bash

CopyEdit

```
sudo ufw default deny incoming
```

```
sudo ufw allow 2200/tcp
```

-
- Use `fail2ban` to block IPs with repeated failed login attempts.

Why? Reduces surface area and mitigates automated attacks.

Rule 3: System Monitoring and Audit Logging

- Monitor `/var/log/auth.log`, `/var/log/syslog`, and use `auditd` for file integrity.
- Write a Python script (`monitor.py`) to alert on failed SSH attempts.

Why? Ensures visibility into suspicious activity and supports forensic analysis.

4. Incident Response Strategy

This policy integrates the Incident Response Plan, which includes:

- **Detection** through log monitoring and tools like `fail2ban`
- **Containment** via automated IP banning and firewall rules
- **Eradication & Recovery** using session control, malware scans, and restoration procedures

Reference: See `Incident_Response_Plan.md` for full steps.

5. CIA Triad and Policy Alignment

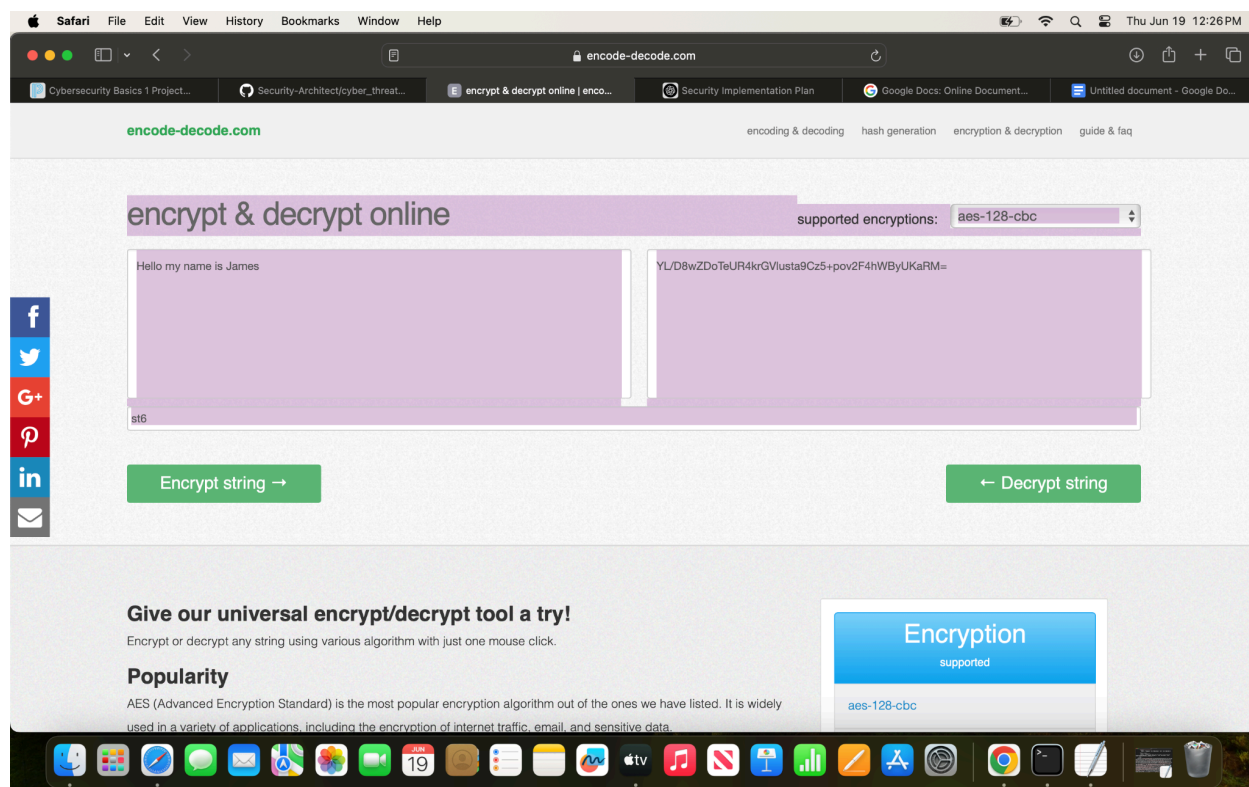
Principle	How This Policy Supports It
Confidentiality	SSH key-based access, encryption tools (e.g., AES), disabled root logins prevent data disclosure.
Integrity	Audit logs, hashing (SHA-256), and file monitoring (<code>auditd</code>) help detect unauthorized changes.
Availability	Firewall protection and brute-force prevention (fail2ban) ensure systems remain operational by reducing attack impact.

6. Review and Maintenance

- All policy rules must be reviewed at least once per semester or after a major incident.
 - Logs should be archived and reviewed weekly.
 - Any new services or configurations must go through a risk assessment before deployment.
-

7. Ethical and Legal Considerations

- Ensure compliance with cybersecurity regulations like **CFAA**, **GDPR**, or **HIPAA** depending on deployment context.
 - Enforce responsible use of scanning and penetration testing tools only within controlled lab environments.
 - All data access and activity monitoring must follow ethical guidelines for privacy and consent.
-



MD5 Hash Generator

Use this generator to create an MD5 hash of a string:

Your String	Free them boys
MD5 Hash	7e96eee4eb6c2fba26d8d5b9e94e7a21
SHA1 Hash	f3bb8e67090182c7bb0fc7e8af42786682368a1b

MD5 Hash Generator

Use this generator to create an MD5 hash of a string:

Your String	Free them boyS
MD5 Hash	ea612570dc09cbcebd5593dda41402e9
SHA1 Hash	4a697f5673bec8b252cb116604738df31a7aa860

10. Legal and Ethical Compliance

10.1 Overview

Security incidents must not only be handled technically, but also **in compliance with legal regulations** and **ethical responsibilities**. This section ensures that our incident response procedures uphold industry standards, avoid liability, and promote responsible cybersecurity behavior.

10.2 Relevant Laws and Regulations

1. Computer Fraud and Abuse Act (CFAA) – United States

The CFAA prohibits unauthorized access to protected systems. In the context of this project, where penetration testing tools (e.g., Hydra, Nmap) are used:

- All activity is conducted on systems owned by or explicitly controlled by the tester (i.e., in a virtual lab).
- There is **no external network scanning** or unauthorized access attempted.

 **Compliance Strategy:** All scans, attacks, and monitoring actions are legal under CFAA because the user has full control and authorization within their lab.

2. General Data Protection Regulation (GDPR) – European Union

GDPR governs the handling of personal data and requires secure storage, controlled access, and data minimization.

Even though this project doesn't process real user data, the following precautions are observed:

- Only system logs (e.g., `/var/log/auth.log`) are used, containing no real personal identifiers.
- All logs and captured data are stored locally in encrypted containers or secure folders.

✅ **Compliance Strategy:** We simulate privacy-sensitive processes and enforce principles of **data minimization** and **secure handling**, aligning with GDPR best practices.

🕒 10.3 Ethical Consideration: Responsible Use of Offensive Tools

Kali Linux tools like **Hydra**, **SQLMap**, and **Nikto** can be used maliciously if applied outside legal boundaries. Ethical use requires:

- Permission from the system owner (yourself in this case)
- A clear educational or defensive intent
- Transparency in documentation and logging

✅ **Ethical Safeguards in This Project:**

- Only virtual machines you own or control are targeted.
 - All activities are logged for traceability.
 - All tools are used to **improve defenses**, not to exploit vulnerabilities for personal gain.
-

🔒 10.4 How the Incident Response Plan Upholds Legal & Ethical Compliance

Principle	How the Plan Complies
Authorization	All testing occurs on self-owned systems.
Data Protection	No sensitive data is collected or exposed.
Transparency	Logs and response steps are fully documented.
Containment Procedures	IPs are blocked only in a test environment.

Ethical Tool Use

Tools used only to simulate attacks ethically.

10.5 Summary

This Incident Response Plan maintains compliance with cybersecurity laws like **CFAA** and **GDPR**, while promoting ethical practices through controlled testing, system ownership, and responsible documentation. Legal and ethical considerations are integral to every stage of the response — from detection through recovery.